

Pramo Jewels

Secure Coding Standards

Document ID: PJ-SCS-001

Version: 1.0

Status: Approved for Development

Field	Value
Project	Pramo Jewels Premium E-Commerce Platform
Purpose	Define secure software development practices for all application components
Audience	Frontend Developers, Backend Developers, Security Team, QA, AI Coding Agents
Version	1.0

Core Secure Coding Practices

Area	Standard
Input Validation	Validate and sanitize all user input on server side.
Authentication	Use Laravel Sanctum, strong password hashing and secure sessions.
Authorization	Enforce RBAC with middleware, Gates and Policies.
Database	Use Eloquent/parameterized queries; never build raw SQL from user input.
Output Encoding	Escape dynamic content to mitigate XSS.
File Uploads	Validate MIME type, size, extension and scan uploads where possible.
Secrets	Store credentials in environment variables or secret manager.
Logging	Mask sensitive values and never log passwords, OTPs or tokens.

OWASP Alignment

Address common risks including injection, broken access control, cryptographic failures, security misconfiguration, XSS and insecure dependencies.

Frontend Security

Use CSP where practical, avoid unsafe HTML rendering, protect against clickjacking, validate client input without relying on it for security.

Backend Security

Centralize validation, implement CSRF protection where applicable, rate limiting, secure error handling and consistent authorization checks.

Dependency Management

Use trusted packages, scan dependencies regularly, remove unused libraries and apply security updates promptly.

Code Reviews

Every pull request must include a security review for authentication, authorization, input validation, sensitive data handling and business logic.

Testing

Perform SAST, dependency scanning, unit tests, integration tests and security-focused regression testing before release.

Incident Response

Report discovered vulnerabilities immediately, assign severity, track remediation and document lessons learned.

Acceptance Criteria

Code complies with project standards, passes automated security checks, peer review and does not introduce known high-severity vulnerabilities.